PENETRATION TEST REPORT

TryHackMe – Bounty Hacker

Prepared By:
Nikhil Patel

Username:
Nikhil

TryHackMe Profile:
https://tryhackme.com/p/nikhilpatel0620

Enterprise Name:
Synthex Dynamics

Project Title:
Modeling data leakage pathways and archive command privilege Escalation in cloud services

Assessment Date:
17 Oct 2026

CONFIDENTIAL | ACADEMIC SUBMISSION

Document Control

Field	Details
Document title	Penetration Test Report – TryHackMe Bounty Hacker
Prepared by	Nikhil Patel
Assessment environment	Authorized TryHackMe training lab
Version	1.0
Date	17 Oct 2026

1. Executive Summary

This report documents a security assessment of the TryHackMe Bounty Hacker training machine. The assessment was performed in an authorized, isolated learning environment to identify exposed services, review potential weaknesses, and demonstrate the impact of a privilege-escalation issue. The workflow included reconnaissance, service enumeration, initial access validation, and local privilege-escalation checks.

During the lab, a privilege-escalation path involving the tar utility and an overly permissive sudo configuration was identified and used to obtain root-level access. This finding demonstrates that allowing a user to run a powerful utility with elevated privileges can lead to complete system compromise. Exact IP addresses, port/service results, evidence screenshots, and flag values should be inserted from the student's own lab notes and screenshots.

2. Scope and Rules of Engagement

In-scope target: TryHackMe Bounty Hacker room machine.

Testing type: Controlled, educational penetration test.

Authorization: Testing was limited to the target provided by the TryHackMe room. No unrelated systems were tested.

Limitations: Results reflect the lab environment and the time at which testing was performed. They should not be treated as a production-system assessment.

3. Objectives

- Identify the target machine and exposed network services.
- Enumerate available services and collect relevant evidence.
- Determine whether an initial-access path is available in the lab.
- Review local privilege-escalation opportunities.
- Validate the impact of the identified weakness and provide remediation recommendations.

4. Assessment Methodology

4.1 Reconnaissance

The target IP address was obtained from the TryHackMe room. Basic reachability and the exposed attack surface were checked.

4.2 Port and Service Enumeration

A port scan was performed to identify open ports, service names, and available version information. Record the actual command and output used in the lab.

4.3 Service Enumeration

Accessible services were examined for useful information, such as anonymous or guest access, readable files, usernames, and other clues relevant to the room.

4.4 Initial Access

The discovered information was assessed to determine whether it could provide a valid route to a normal user account. Include only the steps and evidence that you personally verified.

4.5 Privilege Escalation

After obtaining a low-privileged shell, local permissions and sudo privileges were reviewed. The tar utility was found to be available with elevated privileges; a GTFOBins reference was used to understand the security impact of this configuration.

4.6 Validation and Evidence

The final privilege level was verified in the lab. Screenshots should show the relevant command/output while hiding unrelated personal information.

5. Target Information

Item	Observed Value
Target name	Bounty Hacker
Target IP address	10.48.136.132
Attacking machine	Kali Linux
Attacker hostname	Synthex Dynamics
Kali username	Nikhil

6. Findings Summary

ID	Finding	Severity	Status
F-01	Exposed services / service enumeration	Informational – confirm from scan	Observed; add scan evidence
F-02	Sudo permission on tar enabled root-level command execution	High	Validated in the lab

7. Detailed Finding F-01: Exposed Services

Description

Network enumeration identified services listening on the target machine. Exposed services can increase the attack surface, especially when they allow unnecessary access or disclose useful information.

Evidence

Insert the actual scan output and complete this table from your own results.

Port	State	Service	Version
21/tcp	Open	FTP	vsftpd 3.05
22/tcp	Open	SSH	Openssh 8.2p1
80/tcp	Open	HTTP	Appache httpd 2.4.41



Impact

The impact depends on the service configuration and access controls. Unnecessary or weakly configured services may expose information or provide an entry point for further testing.

Recommendation

Disable services that are not required, restrict access using firewall rules, apply security updates, and enforce strong authentication and least-privilege access.

8. Detailed Finding F-02: Unsafe Sudo Permission for tar

Description

The assessment found that the current user could execute the tar utility through sudo with elevated privileges. Because tar supports features that can execute external commands, an unsafe sudo rule can allow a low-privileged user to execute commands as root. The lab configuration was validated by obtaining a root shell.

Severity

High – the demonstrated configuration can lead to full system compromise. Severity is based on the impact observed in this lab and should be reassessed for any real environment.

Evidence

- Figure 1: Output showing the user's sudo permissions (include the relevant command output).
- Figure 2: The GTFOBins tar reference used to understand the risk (cite the URL in the final submission if your instructor permits external references).
- Figure 3: Terminal output confirming the resulting effective user ID / root privilege.

Impact

A user with this permission may be able to execute arbitrary commands with root privileges, bypassing normal user-level restrictions and potentially accessing or modifying the entire system.

Recommendation

- Remove the unnecessary sudo permission for tar.
- Follow the principle of least privilege and grant only the exact commands required for the user's role.
- Review sudoers entries for other utilities capable of spawning shells or executing external commands.
- Monitor privileged command use and periodically audit sudo configuration.

9. Proof of Concept (PoC) Summary

The issue was reproduced only inside the authorized TryHackMe Bounty Hacker machine. The tester reviewed the sudo permission for tar, consulted GTFOBins for the security implications of the permitted binary, and validated that the configuration could lead to root-level command execution.

Command : sudo tar cf /dev/null /dev/null –checkpoint=1 checkpoint-action=exec=bo

10. Assessment Outcome

The assessment successfully demonstrated a privilege-escalation path to root on the Bounty Hacker lab target. The key security lesson is that allowing powerful utilities to run through sudo can undermine the operating system's privilege boundary. The service-enumeration section must be completed with the actual port scan and room evidence before submission.

Flags captured (enter only the flags you personally obtained):

- User flag: [Paste your verified value, or write 'Not included in this report']
- Root flag: [Paste your verified value, or write 'Not included in this report']

11. Remediation Plan

1. Remove unsafe sudo rules and audit /etc/sudoers and files under /etc/sudoers.d/.
2. Apply least-privilege access controls to all local users.
3. Disable or restrict unnecessary network services.
4. Keep the operating system and installed packages updated.
5. Re-test the configuration after remediation to confirm that root-level execution is no longer possible through the identified path.

12. Evidence Register

Evidence ID	Evidence to insert	File name / page
E-01	Port scan showing open ports and detected services	[Screenshot filename]
E-02	Service enumeration / useful discovery	[Screenshot filename]
E-03	Sudo permission output for tar	[Screenshot filename]
E-04	Root privilege verification	[Screenshot filename]
E-05	TryHackMe completion / flags, if required by instructor	[Screenshot filename]

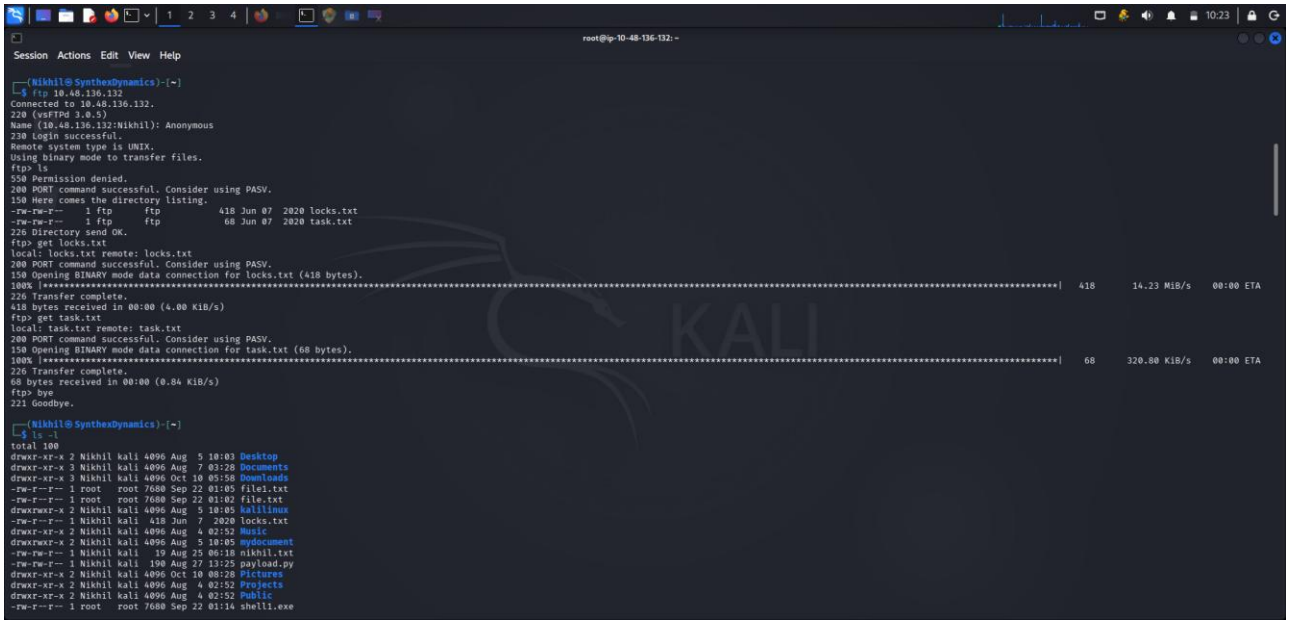
Port scan : Identify open port, service and version using Nmap

Command : nmap -sV -sC -p 21,22,80 10.48.136.132



Enumeration : Examine information of FTP

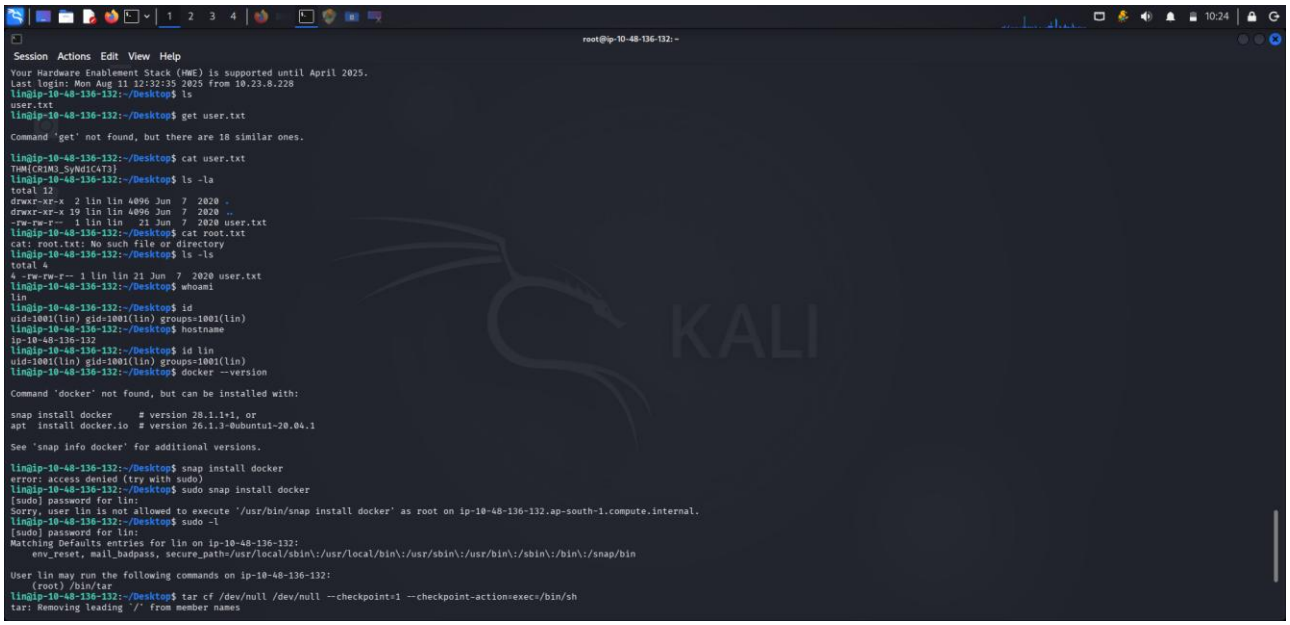
Command : ftp 10.48.136.132



Brute force : finding a password in a password list using hydra

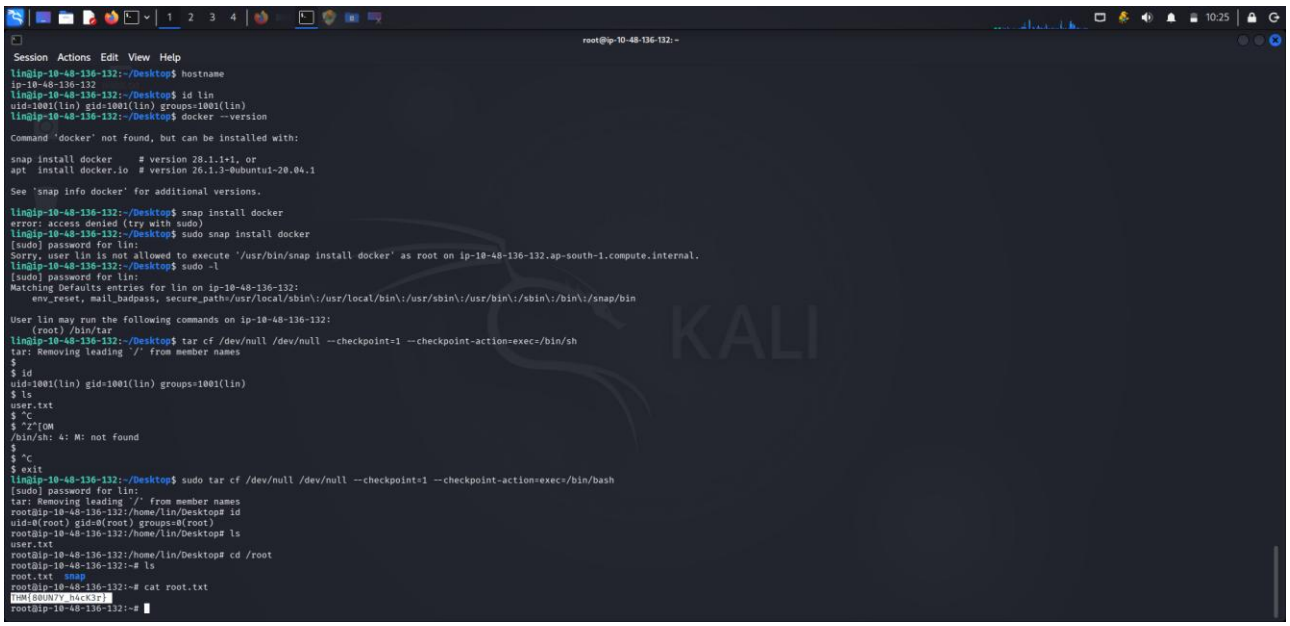
Command : hydra -l lin -p locks.txt ssh://10.48.136.132



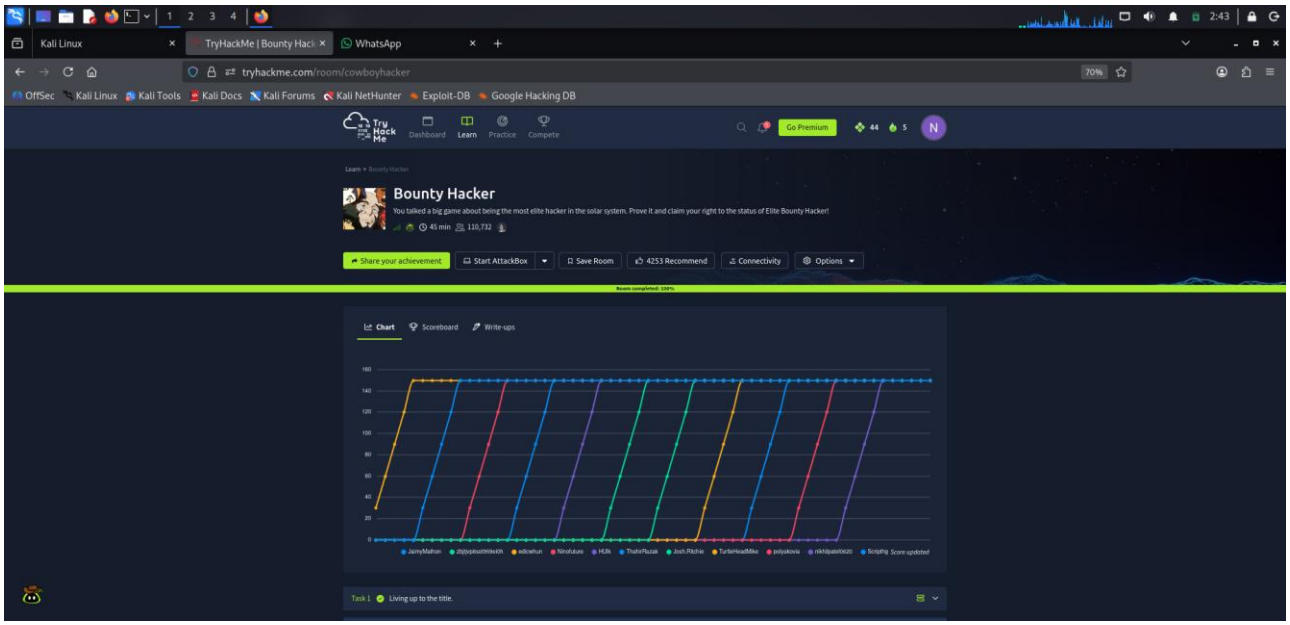


Privilege escalation : Exploited sudo misconfiguration in the tar utility using GTFOBins to obtain root access

Command : sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint=action=exec=bin/bash



Lab Completion : Successfully completed the TryHackMe Bounty Hacker room and achieved the required objectives.



13. Student and TryHackMe Profile Details

Student name: Nikhil Patel

TryHackMe username: Nikhil

TryHackMe profile URL: https://tryhackme.com/p/nikhilpatel0620

Assigned enterprise name: Synthex Dynamics

Assigned project title: Modeling Data Leakage Pathways and Archive Command Privilege Escalation in Cloud Services

14. Conclusion

The Bounty Hacker exercise provided practical experience in reconnaissance, service enumeration, and Linux privilege escalation. The most significant issue validated was the unsafe sudo permission associated with tar, which enabled root-level access in the lab. Applying least privilege and auditing sudo rules would reduce this risk. Before submission, replace all square-bracket placeholders, add genuine screenshots, and verify that every result matches your own assessment.

Appendix A – Commands and Output

Use this appendix to paste the commands and outputs actually used. Keep the output readable and remove unrelated terminal history.

- Target discovery / port scan: nmap -sV -sC -p 10.48.136.132
- Service enumeration:
    - ftp 10.48.136.132
    - ssh lin@10.48.136.132
- Sudo permission check: sudo -l
- Brute force: hydra -l lin -p locks.txt ssh://10.48.136.132
- Privilege verification:
    - whoami
    - id
    - sudo tar cf /dev/null /dev/null --checkpoint=1 –checkpoint=action=exec=bin/bash